



PROS-NC-001

PROCEDIMIENTO CONTRA CÓDIGO MALICIOSO

Sistema de Gestión de Seguridad de la Información – Nivel Central

Versión Oficial Actual v01 – Octubre del 2019

	Responsable	Fecha	Firma
Elaborado	Rodrigo Vidal / Encargado PMG SSI	Octubre 2019	
Revisado	José Villa / Área Seguridad de la Información (Representante Comité de Seguridad)	Octubre 2019	
Aprobado	Gabriel Reveco / Encargado Ciberseguridad (Presidente Comité de Seguridad de la Información)	Octubre 2019	



Contenido

1	PROPÓSITO	3
2	ALCANCE	3
3	TERMINOLOGÍA.....	3
4	DOCUMENTOS APLICABLES	3
5	ROLES Y RESPONSABILIDADES	4
6	PROCEDIMIENTO.....	4
6.1	Mantenimiento de un programa de control de malware.....	4
6.2	Tratamiento para dispositivos de almacenamiento o información externa dudosa	4
6.3	Recuperación de daños a causa de malware.....	5
6.4	Sensibilización de los usuarios	5
7	REGISTROS.....	6
8	DIFUSION	6
9	REVISION Y MEDICION	6
10	CONTROL DE VERSIONES	7

1 PROPÓSITO

Llevar a cabo acciones que permitan prevenir, detectar y corregir los problemas de corrupción de información por la acción de los programas maliciosos denominados “malware” en los distintos ambientes de procesamiento.

2 ALCANCE

El presente procedimiento de prevención de malware se aplica a todos los computadores de escritorio y móviles que se conectan a la red interna de Minsal y sus áreas dependientes, sean estos de propiedad de las unidades que la componen o de terceros que requieran conectarse a dicha red.

Todos los equipos informáticos de Minsal y sus unidades dependientes donde sea implementado este procedimiento y equipos externos que eventualmente deban conectarse a la red de Minsal.

Subsecretarías de Salud Pública y de Redes Asistenciales.

Este procedimiento es aplicable a todos los funcionarios¹ (planta, contrata, reemplazos y suplencia), personal a honorarios y terceros (proveedores, compra de servicios, etc.), que presten servicios para las Subsecretarías de Salud Pública y de Redes Asistenciales y que tengan derechos de acceso a la información que puedan afectar los activos de información del Ministerio de Salud.

Este procedimiento abarca los siguientes controles definidos en la norma NCh-ISO 27001.Of2013:

- A.12.02.01 Controles contra código malicioso
- A.12.06.02 Restricciones sobre la instalación de software

3 TERMINOLOGÍA

MINSAL: Ministerio de Salud.

SGSI: Sistema de Gestión de Seguridad de Información.

Malware: Malware o “software malicioso” es un término amplio que describe cualquier programa o código malicioso que es dañino para los sistemas.

4 DOCUMENTOS APLICABLES

- NCh-ISO27001.Of2013 Tecnología de la información – Técnicas de seguridad – Sistemas de gestión de la seguridad de la información – Requisitos.
- Procedimiento para el control de software operacional.
- Política de pantallas y escritorios limpios.
- Procedimiento Gestión de Incidentes de Seguridad de la Información.

¹ A lo largo del procedimiento cada vez que se mencione funcionario se refiere a: funcionarios (planta, contrata, reemplazos y suplencia), personal a honorarios y terceros (proveedores, compra de servicios, etc.).

5 ROLES Y RESPONSABILIDADES

Todos los usuarios, Administradores de Seguridad, Custodio de las Datos, las Unidades de Informática, Jefe de Servicio, Directores, Jefes de División, Jefes de Departamento y Gestión de Personas son responsables del cumplimiento de este procedimiento.

6 PROCEDIMIENTO

6.1 Mantención de un programa de control de malware

Se debe mantener un sistema automático y estandarizado de control de virus para prevenir y eliminar cualquier tipo de infección, propagación y ejecución causada por ellos en las estaciones de trabajo y servidores y/o en los archivos transmitidos entrantes y salientes vía el servicio de correo electrónico. La actualización de dicho sistema puede ser vía remota o a través de actualizaciones manuales, manteniendo en todo momento la versión más actualizada disponible en todos y cada uno de los equipos protegidos. La verificación de la vigencia de esta actualización deberá ser realizada por el Encargado de Seguridad de la Información / Ciberseguridad de manera aleatoria, se recomienda la implementación de un servidor local que mantenga actualizada las versiones de los usuarios.

Los programas deben permanecer instalados en los equipos centralizados de procesamiento y en las estaciones de trabajo de modo residente, debiendo quedar activos durante todo el tiempo de uso.

Se deben actualizar con la misma periodicidad con la que el proveedor actualiza sus versiones, las versiones de los programas AntiMalware que se utilizan.

Se debe ejecutar un escaneo AntiMalware completo en los equipos, al menos una vez a la semana. Esta tarea deberá ser programada en la herramienta de software AntiMalware por el personal de TIC de cada unidad.

Se debe monitorear la vigencia del contrato con el proveedor del software AntiMalware para asegurar la actualización periódica del software instalado.

Se debe (en la medida de lo posible) facilitar a ciertos usuarios identificados por la organización, la extensión de las licencias del software AntiMalware para sus PC domésticos.

Se debe exigir a las empresas externas que deseen conectarse a la red de la organización, que sus equipos cuenten con software AntiMalware actualizados. Además, dichos equipos deberán ser conectados en una red segmentada (zona con acceso a recursos limitados), aislada de la red donde estén los equipos de la unidad.

Si no es absolutamente necesario que ocupen sus propias máquinas, la organización deberá proveerles un equipo que cuente con todas las medidas de seguridad definidas.

6.2 Tratamiento para dispositivos de almacenamiento o información externa dudosa

Cuando por la naturaleza del trabajo se reciban por ejemplo CD, pen drive, tarjetas de memoria o información externa dudosa (por ejemplo, de empresas que se sabe están

siendo afectadas por malware), se deberá primero que todo, recurrir al Departamento TIC para que sean ellos quienes revisen el contenido. Además, se debe bloquear en los dispositivos de seguridad que controlan el acceso a la red (firewalls), todo contenido que sea considerado riesgoso; especialmente archivos ejecutables.

6.3 Recuperación de daños a causa de malware

Debe existir un plan de recuperación de la información dañada por los virus, tanto para la recuperación de copias de respaldo de los datos operativos como para la reinstalación del software de base y/o aplicativo.

El Departamento TIC debe analizar la magnitud del daño causado por la acción del virus informático. Se debe validar la cantidad de equipos que fueron afectados, cuál es el alcance del virus, qué consecuencias posteriores podría traer, fecha de ocurrencia del evento.

Se deberá también evaluar la integridad de los archivos y/o programas, luego de la eliminación del virus. Para esta tarea, el Encargado de Seguridad de la Información / Ciberseguridad, deberá generar un plan detallado de prueba y verificar su posterior ejecución por parte del Administrador de Seguridad en la unidad.

Es fundamental imprimir el archivo de log correspondiente al producto (software AntiMalware) instalado.

Ante una contaminación masiva, se debe comunicar inmediatamente el estado y acciones a seguir al Encargado de Seguridad de la Información / Ciberseguridad, para que este coordine las acciones necesarias para evitar problemas mayores.

En caso de que se haya perdido información en el proceso de eliminación del virus informático, el Administrador de Seguridad a cargo del AntiMalware, solicitará la copia de seguridad de los archivos dañados o sistema aplicativo y/o software base a custodia.

La solicitud de la reinstalación de sistemas aplicativos, software base y copias de seguridad, será enviada al Custodio Físico de los respaldos con la firma de autorización del Encargado de Seguridad de la Información / Ciberseguridad para que se efectúe el procedimiento de copia o reinstalación.

Siempre que ocurra algún incidente asociado a malware, se debe efectuar una investigación de acuerdo con el Procedimiento de Gestión de Incidentes de Seguridad de la Información, a fin de determinar los responsables y aplicar sanciones a los mismos.

Se deben evaluar los casos de contaminación reiterada de ciertos usuarios, para adoptar medidas tendientes a evitar las reincidencias.

6.4 Sensibilización de los usuarios

Se debe sensibilizar a los usuarios sobre los riesgos de pérdida de información por efecto de los malware y comunicarles la metodología definida para combatirlos.

Se debe efectuar el escaneo de discos periódicamente, al recibir archivos provenientes de sitios externos a la red de la unidad, al bajar archivos de Internet, al utilizar disquetes de terceros, etc.

No se debe divulgar ni considerar ninguna información relacionada con malware que no provenga del Administrador de Sistemas. Si se recibiese algún antecedente de alerta de virus, de otra fuente, se deberá contactar con Soporte TIC, quienes evaluarán la veracidad del comunicado y tomarán las acciones pertinentes.

Los usuarios no deberán intentar trasgredir o sabotear las medidas de seguridad de los sistemas, ni utilizar herramientas, programas o dispositivos con el objeto de evadir controles, interceptar o decodificar contraseñas o acceder a información para la cual no están autorizados.

Se consideran conductas inapropiadas:

- La desinstalación o inhabilitación consciente de las aplicaciones de seguridad del Computador Institucional, por ejemplo, del antivirus.
- La instalación de software no autorizado por el Departamento TIC.
- La cesión, préstamo o utilización del equipo por terceras personas (amigos, parientes o conocidos)
- La modificación de la configuración del sistema operativo u otras aplicaciones que formen parte del software operativo básico del equipo.
- Abrir el equipo y/o cambiar el hardware o dispositivos que lo componen.
- Utilización no autorizada de acceso a páginas Web.

7 REGISTROS

- Inventario de software antimalware.
- Registro de instalación de software antimalware.
- Solicitud para creación de accesos.
- Entrega de credenciales y claves de acceso.
- Registro de incidencias de malware en la red interna.
- Tickets de revisión de equipo por ataque de malware.

8 DIFUSION

La comunicación del presente procedimiento se efectuará de manera que el contenido de la documentación sea accesible y comprensible para todos los usuarios, a lo menos se deberá hacer difusión mediante los siguientes canales:

- Publicación en la intranet de Minsal <http://isalud.minsal.cl/>
- Correo informativo.

9 REVISION Y MEDICION

El presente procedimiento deberá ser revisado a lo menos cada dos años o cuando ocurran cambios significativos para asegurar su continua idoneidad, eficiencia y efectividad.

10 CONTROL DE VERSIONES

Versión	Fecha de Aprobación	Motivo del cambio	Secciones modificadas
01	Octubre 2019	Creación del documento	Todas